

WebVulnPro Security Assessment Report

Generated: 2026-07-17 20:13:47

Executive Summary

Targets Scanned	1
Total Vulnerabilities	8
Critical	0
High	1
Medium	5
Low	2
Informational	0
Overall Risk Score	61/100

Technologies Detected

■ Programming Language

Technology	Version	Confidence
PHP	5.4.31	70%

■ ■ Web Server

Technology	Version	Confidence
Apache	2.4.10	35%

Target: <http://localhost:8080/DVWA/index.php>

Severity	Title	CVSS	Category
HIGH	Missing Content Security Policy (CSP)	7.1	HTTP Headers

MEDIUM	Missing X-Frame-Options Header	5.4	HTTP Headers
MEDIUM	Missing X-Content-Type-Options Header	5.3	HTTP Headers
MEDIUM	Missing Referrer-Policy Header	4.3	HTTP Headers
MEDIUM	Missing Permissions-Policy Header	4.3	HTTP Headers
MEDIUM	Directory Listing Enabled: /icons/	5.3	Misconfiguration
LOW	Server Version Disclosure	2.6	Information Disclosure
LOW	Technology Stack Disclosure (X-Powered-By)	2.6	Information Disclosure

Detailed Findings

[HIGH] Missing Content Security Policy (CSP)

CVSS Score: 7.1 | **Category:** HTTP Headers | **CWE:** CWE-1021

Description: No Content-Security-Policy header found. This makes the application vulnerable to XSS and data injection attacks.

Remediation: Implement a strict CSP. Start with: Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'

Evidence: Header 'content-security-policy' not found in response

[MEDIUM] Missing X-Frame-Options Header

CVSS Score: 5.4 | **Category:** HTTP Headers | **CWE:** CWE-1021

Description: X-Frame-Options header is missing. The site may be vulnerable to clickjacking attacks.

Remediation: Add 'X-Frame-Options: DENY' or 'X-Frame-Options: SAMEORIGIN' header.

Evidence: Header 'x-frame-options' not found in response

[MEDIUM] Missing X-Content-Type-Options Header

CVSS Score: 5.3 | **Category:** HTTP Headers | **CWE:** CWE-693

Description: X-Content-Type-Options header is missing. Browsers may MIME-sniff responses, potentially executing malicious content.

Remediation: Add 'X-Content-Type-Options: nosniff' header.

Evidence: Header 'x-content-type-options' not found in response

[MEDIUM] Missing Referrer-Policy Header

CVSS Score: 4.3 | **Category:** HTTP Headers | **CWE:** CWE-200

Description: Referrer-Policy header is missing. Sensitive information may leak via the Referer header.

Remediation: Add 'Referrer-Policy: strict-origin-when-cross-origin' or 'no-referrer' header.

Evidence: Header 'referrer-policy' not found in response

[MEDIUM] Missing Permissions-Policy Header

CVSS Score: 4.3 | **Category:** HTTP Headers | **CWE:** CWE-16

Description: Permissions-Policy (formerly Feature-Policy) header is missing. Browser features are not restricted.

Remediation: Add Permissions-Policy header to restrict features: Permissions-Policy: geolocation=(), camera=(), microphone=()

Evidence: Header 'permissions-policy' not found in response

[MEDIUM] Directory Listing Enabled: /icons/

CVSS Score: 5.3 | **Category:** Misconfiguration | **CWE:** CWE-548

Description: Directory listing is enabled for '/icons/'.

Remediation: Disable directory listing in web server configuration.

Evidence: URL: http://localhost:8080/icons/

[LOW] Server Version Disclosure

CVSS Score: 2.6 | **Category:** Information Disclosure | **CWE:** CWE-200

Description: The Server header reveals web server software and version information.

Remediation: Remove or obfuscate the Server header to hide implementation details.

Evidence: server: Apache/2.4.10 (Win32) OpenSSL/1.0.1h PHP/5.4.31

[LOW] Technology Stack Disclosure (X-Powered-By)

CVSS Score: 2.6 | **Category:** Information Disclosure | **CWE:** CWE-200

Description: X-Powered-By header reveals the technology stack used by the application.

Remediation: Remove the X-Powered-By header from responses.

Evidence: x-powered-by: PHP/5.4.31